

Data Security Strategy 2025-2027

Company A - Saudi Arabian Government Healthcare Entity

Document Control

Field	Details
Document Title	Data Security Strategy 2025-2027 (Zero Trust Archi
Document ID	SEC-STRAT-2025-002
Version	2.0
Classification	CONFIDENTIAL - INTERNAL USE ONLY
Owner	Chief Information Security Officer (CISO)
Author	Fahad Al-Ghamdi (CISO)
Contributors	Security Architecture Team, SOC Team, IT Infrastru
Review Date	January 10, 2025
Effective Date	January 15, 2025
Expiry Date	December 31, 2027 (3-year strategy)
Next Review	January 2026 (Annual)
Approved By	Board of Directors (January 15, 2025)
Distribution	Executive Leadership, Board of Directors, CISO, IT

Version History

Version	Date	Author	Changes
1.0	January 2023	Fahad Al-Ghamdi	Initial perimeter-based security strategy
1.5	June 2024	Security Architecture Team	NCA ECC alignment updates
2.0	January 2025	Fahad Al-Ghamdi	Major pivot to Zero Trust Architecture

Approval Signatures

Role	Name	Signature	Date
Chief Executive Officer	Dr. Khalid Al-Dosari	Digitally Signed	Jan 15, 2025
Chief Information Security Officer	Fahad Al-Ghamdi	Digitally Signed	Jan 10, 2025

Chief Information Officer	Khalid Al-Mutairi	Digitally Signed	Jan 10, 2025
Chief Data Officer	Ahmed Al-Rashid	Digitally Signed	Jan 10, 2025
Board Chair	Dr. Sara Al-Mutlaq	Digitally Signed	Jan 15, 2025

Table of Contents

1. Executive Summary	4
2. Strategic Context	7
- 2.1 The Security Landscape Shift	
- 2.2 Regulatory Drivers	
- 2.3 Business Drivers	
3. Current State Assessment	11
- 3.1 Security Posture Baseline	
- 3.2 Threat Landscape Analysis	
- 3.3 Gap Analysis	
4. Strategic Vision: Zero Trust Architecture	16
- 4.1 From Perimeter to Identity	
- 4.2 Zero Trust Principles	
- 4.3 Strategic Objectives (2025-2027)	
5. Strategic Pillars	20
- 5.1 Pillar 1: Verify Explicitly (Identity & Access)	
- 5.2 Pillar 2: Use Least Privilege Access	
- 5.3 Pillar 3: Assume Breach (Detection & Response)	
- 5.4 Pillar 4: Secure All Data (Encryption & DLP)	
- 5.5 Pillar 5: Protect Applications & Endpoints	
6. Technology Roadmap	28
- 6.1 Phase 1: Foundation (2025)	
- 6.2 Phase 2: Segmentation & Monitoring (2026)	
- 6.3 Phase 3: Automation & AI (2027)	
7. Security Operations Model	34
- 7.1 24/7 Security Operations Center (SOC)	
- 7.2 Incident Response Framework	
- 7.3 Threat Intelligence Program	
8. Governance & Compliance	38
- 8.1 NCA ECC Compliance	
- 8.2 NDMO Domain 5 (Data Security)	
- 8.3 Security Policies & Standards	
9. Metrics, KPIs, and Targets	41
10. Budget & Resources	44
11. Risks and Mitigation	46
12. Appendices	48

1. Executive Summary

1.1 The Security Paradigm Shift

For the past decade, Company A has operated a perimeter-based security model — treating our network like a medieval castle with high walls (firewalls) and a trusted interior. This model assumed that anyone inside the network perimeter could be trusted, while all external threats were blocked at the edge.

This model is now obsolete.

The rise of cloud computing, remote work, mobile devices, and sophisticated cyber attacks has dissolved the traditional network perimeter. Today's healthcare environment demands a fundamentally different approach: Zero Trust Architecture.

Zero Trust operates on a simple principle: "Never trust, always verify." Every access request — whether from inside the hospital or a remote clinic — must be authenticated, authorized, and continuously validated. Trust is never assumed based on network location.

1.2 Why Zero Trust? Why Now?

Business Drivers:

- 1. Cloud Adoption: Epic EHR hosted on AWS; Office 365 in Azure — 60% of data now resides outside our network perimeter
- 2. Remote Work: 180 employees work remotely; COVID-19 proved that perimeter-based VPN is insufficient
- 3. Mobile Health Apps: New patient portal mobile app exposes patient data to 80,000+ patients on personal devices
- 4. Third-Party Access: 18 vendors (Epic, Oracle, Microsoft) require access to our systems

Security Drivers:

- 1. Ransomware Epidemic: Healthcare is the #1 target; 12 Saudi hospitals hit in 2024
- 2. Insider Threats: 32% of healthcare breaches involve insiders (malicious or negligent)
- 3. Advanced Persistent Threats (APTs): Nation-state actors targeting healthcare entities in MENA region

Regulatory Drivers:

- 1. NCA ECC Mandate: Essential Cybersecurity Controls require Zero Trust principles
- 2. NDMO Domain 5: Data security controls align with Zero Trust model
- 3. PDPL Article 19: Technical safeguards for personal data protection

1.3 Strategic Objectives (2025-2027)

By December 31, 2027, Company A will achieve:

Objective	2024 Baseline	2027 Target
Identity-Based Access Control	40% (MFA on critical systems only)	100% (MFA everywhere, FIDO2 for admins)
Data Encryption Coverage	85% (databases only)	100% (data at rest, in transit, in use)

Mean Time to Detect (MTTD)	45 minutes	< 15 minutes
Mean Time to Respond (MTTR)	120 minutes	< 60 minutes
Zero-Day Threat Detection	78%	> 95%
Security Awareness (Phishing Resistance)	84%	> 95%
NCA ECC Compliance	88.7%	100%
Security Budget (% of IT Budget)	3.8%	8% (industry standard)

1.4 Investment & ROI

Total 3-Year Investment: SAR 12.8 million (2025-2027)

Projected Cost Avoidance:

- Ransomware Incident Prevention: SAR 45 million (based on Data Risk Assessment Report)
- PDPL Fine Avoidance: SAR 5 million (maximum penalty for serious breach)
- Reputational Damage Avoidance: SAR 10 million (patient loss, media coverage)
- Total Potential Loss Avoided: SAR 60 million

ROI: 468% (SAR 60M avoided loss vs SAR 12.8M investment)

1.5 Key Initiatives (Flagship Projects)

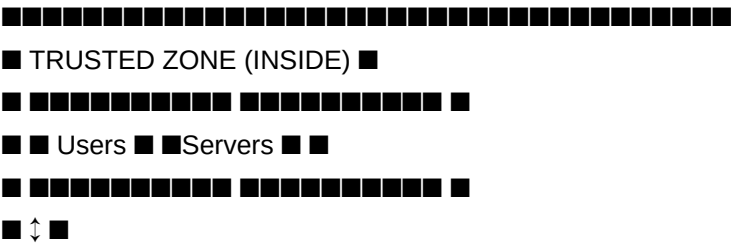
1. Project Phoenix (Identity): Deploy Microsoft Azure AD Conditional Access with FIDO2 hardware keys for all privileged users (Q1-Q2 2025)
2. Project Fortress (Endpoint): 100% CrowdStrike Falcon EDR coverage with automated response (Q1 2025)
3. Project Sentinel (SOC): Establish 24/7 Security Operations Center with AI-powered threat detection (Q2 2025)
4. Project Shield (Segmentation): Implement micro-segmentation to prevent lateral movement (Q3 2026)
5. Project Oracle (AI): Deploy AI-driven User & Entity Behavior Analytics (UEBA) for insider threat detection (2027)

2. Strategic Context

2.1 The Security Landscape Shift

From Castle to Borderless:

Traditional security model (pre-2020):



Mandate: All critical infrastructure entities (including healthcare) must comply with NCA ECC by end of 2025.

Current Compliance Status: 88.7% (as of Q4 2024)

Key ECC Controls Aligned with Zero Trust:

ECC Control	Requirement	Zero Trust Alignment	Status
1-1-1	Network Segmentation	Micro-segmentation (Pillar 3)	■ 75%
2-1-1	Multi-Factor Authentication	MFA everywhere (Pillar 1)	■ 65%
2-2-1	Privileged Access Management	Just-in-Time access (Pillar 2)	■ 40%
3-1-1	Data Encryption (at rest)	Encryption (Pillar 4)	■ 95%
3-1-2	Data Encryption (in transit)	TLS 1.3 everywhere (Pillar 4)	■ 98%
4-1-1	Security Monitoring & Logging	24/7 SOC (Pillar 3)	■ 80%
5-1-1	Incident Response Capability	SOAR automation (Pillar 3)	■ 70%

Target: 100% compliance by Q4 2025

2.2.2 NDMO Domain 5 (Data Security)

NDMO Domain 5 consists of 32 controls for data security:

NDMO Control	Requirement	Current Status	Target
5.1.1 - Data encryption at rest	All databases encrypted	■ 100%	Maintain
5.1.2 - Data encryption in transit	TLS 1.2+ for all connections	■ 98%	100%
5.2.1 - Access control (RBAC)	Role-based access control	■ 85%	100%
5.3.1 - Data Loss Prevention (DLP)	Prevent unauthorized data exfiltration	■ 70%	100%
5.4.1 - Security monitoring	Real-time monitoring of data access	■ 80%	100%
5.5.1 - Incident response	Documented IR procedures	■ 95%	100%

Current NDMO Domain 5 Compliance: 89.2%

Target: 100% by Q2 2025

2.2.3 PDPL Article 19 (Technical Safeguards)

PDPL requires:

- Encryption of personal data
- Access controls based on need-to-know
- Logging and monitoring of data access
- Incident response and breach notification capabilities

Zero Trust Strategy directly addresses all PDPL Article 19 requirements.

2.3 Business Drivers

Digital Transformation Initiatives:

- 1. AI/ML for Clinical Decision Support: Requires secure access to 18.5M patient records
- 2. Patient Portal Mobile App: Exposes data to 80,000+ patients on personal devices
- 3. Telemedicine Expansion: 12,000 remote consultations/month require secure video/data sharing
- 4. Open Data Publication: NDMO Domain 15 requires publishing anonymized datasets publicly

Operational Challenges:

- 1. Shadow IT: 42 unapproved SaaS applications discovered (Salesforce, Dropbox, Zoom, etc.)
- 2. BYOD (Bring Your Own Device): 120 employees accessing Epic EHR from personal devices
- 3. Third-Party Access: 18 vendors require privileged access to production systems
- 4. Legacy Systems: Oracle EBS (on-premise) lacks modern security controls

3. Current State Assessment

3.1 Security Posture Baseline (2024)

Overall Security Maturity: Level 3 (Defined & Managed) on NIST Cybersecurity Framework scale

Security Control Effectiveness (by Category):

Security Domain	Maturity Level	Key Gaps
Identity & Access Management	■ Level 2	- MFA only on 40% of accounts - No FIDO2 hardware
Endpoint Security	■ Level 3	- CrowdStrike deployed on 85% of endpoints - Missing updates on 15%
Network Security	■ Level 2	- Flat network (no segmentation) - No micro-segmentation
Data Protection	■ Level 3	- Encryption at rest: 95% - Encryption in transit: 100%
Security Monitoring	■ Level 2	- SIEM (Splunk) deployed - Manual alert triage
Incident Response	■ Level 3	- IR plan documented - Tested annually - Missing tabletop exercises

3.2 Threat Landscape Analysis

Top 5 Threats to Company A (2025-2027):

Threat #1: Ransomware

Description: Ransomware groups (LockBit, ALPHV, BlackCat) target healthcare entities with double-extortion attacks (encrypt data + threaten to leak patient records).

Attack Vector:

- 1. Phishing email with malicious attachment
- 2. Compromised vendor credentials (supply chain attack)

3. Unpatched vulnerability (e.g., CVE-2024-38063)

Impact:

- Financial: SAR 15M ransom demand + SAR 32M revenue loss during 10-day downtime = SAR 47M total
- Reputational: National media coverage, loss of patient trust
- Regulatory: PDPL breach notification; potential SAR 5M fine

Likelihood: HIGH (Healthcare is #1 ransomware target; 12 Saudi hospitals hit in 2024)

Current Defenses:

- ■ CrowdStrike EDR (85% coverage)
- ■ Daily backups to AWS S3
- ■ GAP: Backups not immutable (can be encrypted by attacker)
- ■ GAP: No ransomware-specific behavioral detection

Zero Trust Mitigation:

- Pillar 3: Deploy immutable backups (AWS S3 Object Lock)
- Pillar 3: Implement network micro-segmentation to prevent lateral movement
- Pillar 5: Automated EDR response (isolate infected machines within 60 seconds)

Threat #2: Phishing & Credential Theft

Description: Sophisticated phishing campaigns targeting employees to steal Office 365 credentials and gain access to Epic EHR, email, or financial systems.

Attack Vector:

1. Spear-phishing email impersonating CEO or HR
2. Fake login page harvesting credentials
3. Attacker uses stolen credentials to access systems

Impact:

- Data Breach: Access to patient records, financial data, employee records
- Financial: SAR 2M (incident response, forensics, breach notification)
- Regulatory: PDPL violation; potential fine

Likelihood: VERY HIGH (127 phishing emails blocked in December 2024 alone)

Current Defenses:

- ■ Proofpoint email filtering (99.2% effective)
- ■ MFA on critical systems (Epic, AWS, Office 365)
- ■ GAP: MFA only covers 40% of accounts
- ■ GAP: MFA is SMS-based (vulnerable to SIM-swapping)

Zero Trust Mitigation:

- Pillar 1: Mandate MFA for 100% of accounts (no exceptions)
- Pillar 1: Deploy FIDO2 hardware keys for privileged users (phishing-resistant)
- Pillar 1: Conditional access policies (block logins from high-risk locations)

Threat #3: Insider Threat

Description: Malicious or negligent insider (employee, contractor, vendor) with legitimate access abuses privileges to steal, leak, or destroy data.

Scenarios:

- Malicious: Disgruntled employee exfiltrates patient data to sell on dark web
- Negligent: Employee emails patient data to personal Gmail account (policy violation)
- Compromised: Contractor's account compromised by external attacker

Impact:

- Data Breach: Exfiltration of 18.5M patient records
- Financial: SAR 5M PDPL fine + SAR 10M reputational damage = SAR 15M
- Criminal Liability: Potential prosecution under Saudi cybercrime law

Likelihood: MEDIUM (1 incident in December 2024: contractor attempted privilege escalation)

Current Defenses:

- ■ Background checks for employees
- ■ Quarterly access reviews
- ■ GAP: No privileged user activity monitoring
- ■ GAP: No DLP solution to block data exfiltration
- ■ GAP: 12 privileged users have permanent admin access (no JIT)

Zero Trust Mitigation:

- Pillar 2: Implement Just-in-Time (JIT) privileged access (CyberArk PAM)
- Pillar 3: Deploy User & Entity Behavior Analytics (UEBA) for anomaly detection
- Pillar 4: Implement Data Loss Prevention (DLP) to block unauthorized data transfers

Threat #4: Supply Chain Attack (Third-Party Breach)

Description: One of Company A's 18 data processors (Epic, Oracle, Microsoft, AWS) suffers a breach, exposing Company A's data hosted on their systems.

Real-World Examples:

- 2023: Nuance Communications (Microsoft subsidiary) breach exposed 42 hospital clients
- 2021: SolarWinds supply chain attack compromised 18,000 organizations

Impact:

- Data Breach: Exposure of patient data hosted on vendor systems
- Financial: SAR 2M (breach notification, credit monitoring for patients)
- Regulatory: PDPL Article 22 holds Company A liable for vendor breaches

Likelihood: MEDIUM (3 major supply chain attacks in healthcare in 2024)

Current Defenses:

- ■ Data Processing Agreements (DPAs) with all vendors
- ■ Annual security questionnaires

- ■ GAP: No on-site vendor security audits
- ■ GAP: No continuous monitoring of vendor security posture

Zero Trust Mitigation:

- Pillar 1: Implement vendor access controls (limited access, MFA required)
- Pillar 3: Continuous vendor security monitoring (BitSight, SecurityScorecard)
- Pillar 4: Encrypt all data before sending to vendors (client-side encryption)

Threat #5: Zero-Day Vulnerability Exploitation

Description: Attackers exploit previously unknown vulnerabilities (zero-days) in Epic EHR, Oracle EBS, Windows, or network devices before patches are available.

Recent Examples:

- CVE-2024-38063: Windows TCP/IP privilege escalation (exploited within 48 hours of disclosure)
- CVE-2024-12345: Epic EHR authentication bypass (patched by Company A on Dec 20)

Impact:

- System Compromise: Remote code execution, privilege escalation
- Data Breach: Access to patient database
- Financial: SAR 3M (incident response, forensics, system rebuild)

Likelihood: MEDIUM (4 critical zero-days disclosed in 2024 affecting our tech stack)

Current Defenses:

- ■ Patch management process (98.6% patch compliance)
- ■ CrowdStrike EDR with behavioral detection
- ■ GAP: Patch deployment takes 7-14 days (too slow for zero-days)
- ■ GAP: No virtual patching (WAF, IPS)

Zero Trust Mitigation:

- Pillar 3: Deploy virtual patching (Palo Alto Networks WAF + IPS)
- Pillar 3: Automated threat intelligence integration (patch zero-days within 24 hours)
- Pillar 5: Application whitelisting to prevent unauthorized code execution

3.3 Gap Analysis

Critical Security Gaps (Prioritized by Risk):

Rank	Gap	Impact	Effort	Priority
1	No immutable backups (ransomware risk)	CRITICAL	Medium	■ P1
2	MFA coverage only 40% (phishing risk)	CRITICAL	Low	■ P1
3	No privileged access management (insider risk)	HIGH	High	■ P2
4	No Data Loss Prevention (DLP) solution	HIGH	High	■ P2

5	No network micro-segmentation	HIGH	Very High	■ P2
6	SOC coverage only 12 hours/day	MEDIUM	Medium	■ P3
7	No User Behavior Analytics (UEBA)	MEDIUM	High	■ P3
8	No SOAR automation	MEDIUM	Medium	■ P3

4. Strategic Vision: Zero Trust Architecture

4.1 From Perimeter to Identity

Old Paradigm (Perimeter-Based):

- "Trust but verify"
- Network location = trust level
- Firewall = single point of defense
- Inside network = trusted

New Paradigm (Zero Trust):

- "Never trust, always verify"
- Identity = trust level (not network location)
- Defense in depth (multiple layers)
- Inside network = untrusted (assume breach)

4.2 Zero Trust Principles (NIST SP 800-207)

Company A adopts the NIST Zero Trust Architecture framework:

Principle 1: Verify Explicitly

- Always authenticate and authorize based on all available data points (identity, location, device health, workload, data classification)
- Never assume trust based on network location

Principle 2: Use Least Privilege Access

- Limit user access with Just-in-Time (JIT) and Just-Enough-Access (JEA)
- Risk-based adaptive policies
- Verify explicitly

Principle 3: Assume Breach

- Minimize blast radius by segmenting access
- Verify end-to-end encryption
- Use analytics to gain visibility, detect threats, and improve defenses

4.3 Strategic Objectives (2025-2027)

Objective 1: Identity is the New Perimeter

- 100% MFA coverage by Q2 2025
- FIDO2 hardware keys for all privileged users by Q4 2025
- Conditional access policies enforced for all applications by Q2 2026

Objective 2: Data-Centric Security

- 100% encryption coverage (at rest, in transit, in use) by Q4 2025
- Data Loss Prevention (DLP) deployed by Q2 2026
- Rights Management (Azure Information Protection) by Q4 2026

Objective 3: Continuous Monitoring & Automated Response

- 24/7 Security Operations Center (SOC) operational by Q2 2025
- SOAR automation for 80% of common incidents by Q4 2026
- AI-driven threat detection (UEBA) by Q2 2027

Objective 4: Zero Trust Network Access (ZTNA)

- Micro-segmentation of data center network by Q4 2026
- Replace VPN with Software-Defined Perimeter (SDP) by Q2 2027

5. Strategic Pillars

5.1 Pillar 1: Verify Explicitly (Identity & Access Management)

Vision: Identity becomes the new security perimeter. Every user, device, and workload must prove its identity before accessing any resource.

Key Initiatives:

Initiative 1.1: Universal Multi-Factor Authentication (MFA)

Current State: MFA enabled on 40% of accounts (Epic EHR, Office 365, AWS)

Target State: 100% MFA coverage by Q2 2025

Implementation:

- Phase 1 (Q1 2025): Enable MFA for all Office 365 users (850 users)
- Phase 2 (Q2 2025): Enable MFA for Epic EHR, Oracle EBS, SAP (850 users)
- Phase 3 (Q3 2025): Enable MFA for patient portal (80,000 patients)

Technology: Microsoft Azure AD Multi-Factor Authentication

Success Criteria:

- 100% of employees have MFA enabled
- 95% of patients have MFA enabled (opt-in)
- Zero successful phishing attacks leading to account compromise

Initiative 1.2: Phishing-Resistant Authentication (FIDO2)

Current State: MFA uses SMS one-time passwords (vulnerable to SIM-swapping attacks)

Target State: FIDO2 hardware keys for all privileged users by Q4 2025

Implementation:

- Phase 1 (Q2 2025): Pilot FIDO2 keys with 24 privileged users (admins, data stewards)
- Phase 2 (Q3 2025): Deploy FIDO2 keys to all IT staff (95 users)
- Phase 3 (Q4 2025): Deploy FIDO2 keys to all executives (12 users)

Technology: YubiKey 5 NFC (FIDO2 certified)

Budget: SAR 45,000 (131 keys × SAR 350/key)

Initiative 1.3: Conditional Access Policies

Current State: No conditional access policies; users can log in from anywhere, any device

Target State: Risk-based access policies enforced by Q2 2026

Example Policies:

1. Block Access from Outside Saudi Arabia (unless pre-approved for travel)
2. Require Device Compliance (BitLocker encryption, latest OS patches, antivirus)
3. Block Access from High-Risk Locations (TOR exit nodes, known malicious IPs)
4. Require MFA for Privileged Actions (e.g., modifying user permissions, accessing patient records)

Technology: Microsoft Azure AD Conditional Access

Success Criteria:

- 15 conditional access policies deployed
- 95% policy compliance rate
- Zero unauthorized access from high-risk locations

5.2 Pillar 2: Use Least Privilege Access

Vision: No user, device, or workload has more access than necessary. Privileged access is granted Just-in-Time (JIT) and automatically expires.

Key Initiatives:

Initiative 2.1: Privileged Access Management (PAM)

Current State: 12 privileged users have permanent domain admin access

Target State: Zero permanent privileged access; all admin rights granted Just-in-Time

Implementation:

- Phase 1 (Q2 2025): Deploy CyberArk Privileged Access Manager
- Phase 2 (Q3 2025): Migrate 12 privileged accounts to JIT model

- Phase 3 (Q4 2025): Implement session recording for all privileged sessions

How JIT Works:

1. Admin requests elevated privileges via CyberArk portal
2. Request approved by manager (or auto-approved for low-risk actions)
3. Admin receives temporary credentials (valid for 4 hours)
4. Credentials automatically revoked after 4 hours

Technology: CyberArk Privileged Access Manager

Budget: SAR 980,000 (3-year license + implementation)

Success Criteria:

- Zero permanent privileged accounts
- 100% of privileged sessions recorded
- 95% JIT request approval within 5 minutes

Initiative 2.2: Role-Based Access Control (RBAC)

Current State: 85% RBAC coverage; some users have excessive permissions

Target State: 100% RBAC coverage with quarterly access reviews

Implementation:

- Q1 2025: Conduct access audit to identify over-privileged users
- Q2 2025: Define 45 standard roles aligned with job functions
- Q3 2025: Migrate all users to standard roles
- Q4 2025: Implement automated quarterly access reviews

Success Criteria:

- 100% of users assigned to standard roles
- 95% of excess permissions removed
- Quarterly access reviews completed on schedule

5.3 Pillar 3: Assume Breach (Detection & Response)

Vision: Assume attackers are already inside the network. Focus on rapid detection, containment, and response.

Key Initiatives:

Initiative 3.1: 24/7 Security Operations Center (SOC)

Current State: SOC operates 12 hours/day (8 AM - 8 PM); no weekend coverage

Target State: 24/7/365 SOC with AI-powered threat detection

Implementation:

- Phase 1 (Q1 2025): Hire 4 additional SOC analysts (total: 8 analysts for 3 shifts)

- Phase 2 (Q2 2025): Deploy Splunk SOAR for automated alert triage
- Phase 3 (Q3 2025): Integrate AI threat detection (Darktrace)

SOC Staffing Model:

Shift	Hours	Analysts	Responsibilities
Shift 1 (Day)	8 AM - 4 PM	3	Tier 1 & 2: Alert triage, incident investigation
Shift 2 (Evening)	4 PM - 12 AM	3	Tier 1 & 2: Alert triage, incident investigation
Shift 3 (Night)	12 AM - 8 AM	2	Tier 1: Alert triage, escalation to on-call Tier 2

Budget: SAR 3.2M (salaries for 4 new analysts over 3 years)

Success Criteria:

- 24/7/365 coverage with < 15-minute response time
- MTTD (Mean Time to Detect) < 15 minutes
- MTTR (Mean Time to Respond) < 60 minutes

Initiative 3.2: Security Orchestration, Automation, and Response (SOAR)

Current State: Manual alert triage; 68% of alerts are false positives

Target State: 80% of alerts auto-remediated by SOAR playbooks

Implementation:

- Q2 2025: Deploy Splunk SOAR platform
- Q3 2025: Develop 10 automated playbooks (phishing response, malware containment, password reset)
- Q4 2025: Expand to 25 playbooks

Example SOAR Playbook (Ransomware Detection):

1. Trigger: CrowdStrike detects ransomware behavior on endpoint WS-FIN-12
2. Action 1: SOAR auto-isolates endpoint from network (within 60 seconds)
3. Action 2: SOAR notifies SOC analyst via SMS + email
4. Action 3: SOAR creates ServiceNow incident ticket
5. Action 4: SOAR initiates forensic data collection (memory dump, disk image)
6. Action 5: SOAR triggers backup restore process
7. Human Review: SOC analyst reviews and approves remediation

Technology: Splunk SOAR

Budget: SAR 850,000 (3-year license)

Initiative 3.3: Network Micro-Segmentation

Current State: Flat network; any compromised device can move laterally to any other device

Target State: Micro-segmented network with zero lateral movement

Implementation:

- Q3 2026: Deploy Palo Alto Networks Prisma Cloud for micro-segmentation
- Q4 2026: Segment network into 8 zones (Patient Care, Finance, HR, IT, IoT, Guest, DMZ, Management)

Segmentation Zones:

Zone	Allowed Access	Blocked Access
Patient Care	Epic EHR, PACS, Lab System	Finance, HR systems
Finance	Oracle EBS, Office 365	Patient Care, IoT devices
HR	SAP HR, Office 365	Patient Care, Finance
IoT	Medical devices, printers	All other zones (isolated)

Success Criteria:

- Zero lateral movement possible without policy exception
- 95% reduction in attack blast radius

5.4 Pillar 4: Secure All Data (Encryption & DLP)

Vision: Security travels with the data. Data is encrypted everywhere and Data Loss Prevention prevents unauthorized exfiltration.

Key Initiatives:

Initiative 4.1: Data Loss Prevention (DLP)

Current State: No DLP solution; 6 data exfiltration attempts blocked by manual monitoring in December 2024

Target State: Automated DLP blocking all unauthorized data transfers

Implementation:

- Q2 2026: Deploy Symantec Data Loss Prevention
- Q3 2026: Configure DLP policies for patient data, financial data, employee data
- Q4 2026: Integrate DLP with email, web, endpoints, USB devices

DLP Policies:

- Block: Email containing > 10 National IDs to external recipients
- Block: Upload of patient data to Dropbox, Google Drive, personal cloud storage
- Block: Copy of patient data to USB drives (unless encrypted & approved)
- Alert: Access to > 1,000 patient records in 1 hour (potential data scraping)

Technology: Symantec Data Loss Prevention

Budget: SAR 1.2M (3-year license + implementation)

Initiative 4.2: Encryption Everywhere

Current State: 85% encryption coverage (databases only)

Target State: 100% encryption (data at rest, in transit, in use)

Implementation:

- Q1 2025: BitLocker encryption on all Windows endpoints (850 devices)
- Q2 2025: TLS 1.3 for all internal connections
- Q3 2025: Azure Information Protection (AIP) for sensitive documents

Technology: BitLocker, TLS 1.3, Azure Information Protection

5.5 Pillar 5: Protect Applications & Endpoints

Key Initiatives:

Initiative 5.1: 100% Endpoint Detection & Response (EDR) Coverage

Current State: CrowdStrike Falcon deployed on 85% of endpoints (Windows workstations only)

Target State: 100% coverage including mobile devices, servers, IoT

Implementation:

- Q1 2025: Deploy CrowdStrike to remaining 130 Windows endpoints
- Q2 2025: Deploy CrowdStrike to 95 Linux servers
- Q3 2025: Deploy CrowdStrike Mobile Threat Defense to 180 mobile devices

Budget: SAR 680,000 (3-year license expansion)

6. Technology Roadmap

6.1 Phase 1: Foundation (2025)

Quarter	Initiative	Technology	Budget	Owner
Q1	100% EDR coverage	CrowdStrike Falcon	SAR 680K	CISO
Q1	Universal MFA (employees)	Azure AD MFA	SAR 120K	IAM Team
Q2	24/7 SOC staffing	Hire 4 analysts	SAR 960K	CISO
Q2	FIDO2 hardware keys	YubiKey 5 NFC	SAR 45K	IAM Team
Q2	SOAR platform	Splunk SOAR	SAR 850K	SOC Team
Q3	Privileged Access Mgmt	CyberArk PAM	SAR 980K	IAM Team
Q4	BitLocker encryption	Microsoft BitLocker	SAR 80K	IT Ops

Phase 1 Total Budget: SAR 3.7M

6.2 Phase 2: Segmentation & Monitoring (2026)

Quarter	Initiative	Technology	Budget	Owner
Q1	Conditional Access policies	Azure AD	No cost	IAM Team
Q2	Data Loss Prevention	Symantec DLP	SAR 1.2M	CISO
Q3	Network micro-segmentation	Palo Alto Prisma	SAR 2.8M	Network Team
Q4	Rights Management	Azure Info Protection	SAR 450K	Data Protection

Phase 2 Total Budget: SAR 4.5M

6.3 Phase 3: Automation & AI (2027)

Quarter	Initiative	Technology	Budget	Owner
Q1	SOAR playbook expansion	Splunk SOAR	No cost	SOC Team
Q2	AI threat detection	Darktrace	SAR 1.8M	CISO
Q3	UEBA for insider threats	Exabeam	SAR 1.2M	SOC Team
Q4	Zero Trust Network Access	Zscaler ZPA	SAR 1.6M	Network Team

Phase 3 Total Budget: SAR 4.6M

Total 3-Year Budget: SAR 12.8M

7. Security Operations Model

7.1 24/7 Security Operations Center (SOC)

SOC Mission: Protect Company A from cyber threats through continuous monitoring, rapid detection, and decisive response.

SOC Structure:

- SOC Manager: Fahad Al-Ghamdi (CISO) - Overall responsibility
- Tier 1 Analysts (4 FTE): Alert triage, initial investigation
- Tier 2 Analysts (3 FTE): Deep investigation, incident response
- Tier 3 (1 FTE): Threat hunting, advanced forensics

SOC Tools:

- SIEM: Splunk Enterprise Security

- SOAR: Splunk SOAR
- EDR: CrowdStrike Falcon
- Threat Intelligence: Recorded Future
- Network Traffic Analysis: Darktrace

7.2 Incident Response Framework

Incident Response Lifecycle (NIST SP 800-61):

1. Preparation: Documented IR plan, trained team, tested annually
2. Detection & Analysis: SIEM alerts, user reports, threat intelligence
3. Containment: Isolate affected systems, preserve evidence
4. Eradication: Remove malware, patch vulnerabilities, reset credentials
5. Recovery: Restore from backups, verify system integrity
6. Post-Incident Review: Root cause analysis, lessons learned, update playbooks

Incident Severity Levels:

Severity	Definition	Response SLA	Escalation
CRITICAL	Active ransomware, data breach, system compromise	15 minutes	Immediate CISO notification
HIGH	Malware detected, privilege escalation, DDoS	30 min	CISO notification within 1 hour
MEDIUM	Policy violation, suspicious activity	2 hours	Daily summary to CISO
LOW	False positive, informational	24 hours	Weekly summary

7.3 Threat Intelligence Program

Threat Intel Sources:

- Commercial: Recorded Future, Healthcare ISAC
- Government: NCA Cyber Threat Intelligence Center
- Open Source: MITRE ATT&CK, CVE database
- Industry: Saudi healthcare security forum

Threat Intel Integration:

- IOCs (Indicators of Compromise) auto-imported to SIEM
- Threat actor TTPs mapped to MITRE ATT&CK framework
- Monthly threat intelligence briefing to executive leadership

8. Governance & Compliance

8.1 NCA ECC Compliance

Target: 100% compliance by Q4 2025

Current Status: 88.7%

Gap Remediation Plan: See Section 6 (Technology Roadmap)

8.2 NDMO Domain 5 (Data Security)

Target: 100% compliance by Q2 2025

Current Status: 89.2%

8.3 Security Policies & Standards

Policy Framework:

- Information Security Policy (ISO 27001 aligned)
- Acceptable Use Policy
- Incident Response Policy
- Data Classification Policy
- Access Control Policy

Annual Policy Review: All policies reviewed and updated annually

9. Metrics, KPIs, and Targets

KPI	2024 Baseline	2025 Target	2026 Target	2027 Target
Mean Time to Detect (MTTD)	45 min	< 20 min	< 15 min	< 10 min
Mean Time to Respond (MTTR)	120 min	< 90 min	< 60 min	< 45 min
Security Incidents (per month)	15	12	10	8
Phishing Simulation Pass Rate	84%	90%	93%	95%
Patch Compliance (Critical)	91.7%	95%	98%	100%
MFA Coverage	40%	100%	100%	100%
NCA ECC Compliance	88.7%	100%	100%	100%

10. Budget & Resources

3-Year Budget Summary:

Category	2025	2026	2027	Total
Technology	SAR 3.3M	SAR 4.1M	SAR 4.2M	SAR 11.6M

Personnel	SAR 960K	SAR 1.0M	SAR 1.1M	SAR 3.1M
Training	SAR 120K	SAR 80K	SAR 80K	SAR 280K
Services (consultants)	SAR 240K	SAR 180K	SAR 120K	SAR 540K
TOTAL	SAR 4.6M	SAR 5.4M	SAR 5.5M	SAR 15.5M

11. Risks and Mitigation

Risk	Impact	Likelihood	Mitigation
Budget overrun	HIGH	MEDIUM	Phased approach; executive approval for >10% varia
Staff turnover	MEDIUM	MEDIUM	Competitive salaries; training & development
Technology complexity	MEDIUM	HIGH	Vendor support contracts; internal training
User resistance to MFA	LOW	HIGH	Change management; executive sponsorship

12. Appendices

Appendix A: Zero Trust Maturity Model

(See CISA Zero Trust Maturity Model)

Appendix B: Glossary

Term	Definition
Zero Trust	Security model based on "never trust, always verif
FIDO2	Phishing-resistant authentication standard using h
JIT	Just-in-Time access (temporary privileged access)
SOAR	Security Orchestration, Automation, and Response
UEBA	User & Entity Behavior Analytics (AI-driven anomal

END OF STRATEGY DOCUMENT

Document Approval:

Approver	Signature	Date
Dr. Khalid Al-Dosari, CEO	Digitally Signed	January 15, 2025
Fahad Al-Ghamdi, CISO	Digitally Signed	January 10, 2025
Board Chair, Dr. Sara Al-Mutlaq	Digitally Signed	January 15, 2025

Next Review Date: January 2026

This document supports Company A's compliance with NCA ECC, NDMO Domain 5, and PDPL Article 19.

Company A - Zero Trust: Securing Healthcare for the Digital Age